

T0.10 — WHAPI_WEBHOOK_TOKEN obligatorio

Resumen de implementacion · Fecha: 2026-05-01 · Sin merge, sin deploy. · Rama lista para revision.

Implementado y testado. 3 archivos modificados, 468 tests verde, branch *pr/whapi-webhook-token-obligatorio* en GitHub. Cierra deuda P0 latente: el endpoint `/webhook` con `WHATSAPP_PROVIDER=whapi` ya no aceptaria payloads forjados sin custom header. PR preventivo — provider activo sigue siendo Meta, asi que el deploy actual no se ve afectado.

Identificadores

Item	Valor
Commit	57584d4
Mensaje	fix(seguridad): WHAPI_WEBHOOK_TOKEN obligatorio en produccion (T0.10)
Rama local	pr/whapi-webhook-token-obligatorio
Rama remota	origin/pr/whapi-webhook-token-obligatorio
Crear PR en GitHub	https://github.com/celestinojbm/Dona-agent/pull/new/pr/whapi-webhook-token-obligatorio
main local	49978a9 (igual a origin/main, INTACTO)
origin/main	49978a9 (sin push de este PR a main)

Archivos tocados (los 3 autorizados)

Archivo	Cambio
agent/providers/whapi.py	+ check fail-fast en <code>ProveedorWhapi.__init__</code> : si <code>ENVIRONMENT=production</code> y <code>WHAPI_WEBHOOK_TOKEN</code> vacio (<code>post.strip()</code>) -> <code>RuntimeError</code> . + metodo <code>_verificar_firma</code> con <code>hmac.compare_digest</code> (timing-safe). + invocacion al inicio de <code>parsear_webhook</code> (rechaza con [] si firma falla). + import <code>hmac</code> . Lee <code>ENVIRONMENT</code> en cada llamada para tests con monkeypatch.
.env.example	+ bloque documental para <code>WHAPI_WEBHOOK_TOKEN</code> (obligatoria en produccion si <code>provider=whapi</code>). + <code>WHAPI_WEBHOOK_HEADER</code> opcional (default <code>X-Webhook-Token</code>). + nota legacy sobre <code>WHAPI_API_URL</code> (no usada en codigo, vestigio borrrable). Sin valores reales.
tests/test_providers.py	+ <code>TestWhapiWebhookValidation</code> con 8 tests (incluye 1 extra de header personalizable via env). + helpers <code>_make_whapi_text_msg</code> y <code>_make_whapi_request</code> .

Total: 3 archivos, +242 lineas, -0 lineas.

Diff resumido

```
.env.example | 23 ++++++
agent/providers/whapi.py | 81 ++++++
tests/test_providers.py | 138 ++++++
3 files changed, 242 insertions(+)
```

Tests ejecutados y resultado

Suite	Resultado
pytest tests/test_providers.py -x -q	37 passed en 0.58 s (29 previos + 8 nuevos en TestWhapiWebhookValidation)
pytest -q (suite completa)	468 passed en 54.69 s, exit 0

Sin regresiones. Suite paso de 460 (post-T0.4) a 468 — +8 tests netos del PR.

Tests nuevos en TestWhapiWebhookValidation

- `test_dev_sin_token_acepta_payload` — en development sin token, `_verificar_firma` retorna `True`.
- `test_production_sin_token_levanta_runtime_error` — al instanciar `ProveedorWhapi` en prod sin token, `RuntimeError`.
- `test_production_secret_solo_whitespace_levanta` — `' '` cuenta como vacio (`.strip()`).
- `test_production_con_token_no_levanta_en_init` — con token valido, `__init__` pasa.
- `test_production_token_valido_acepta` — con header correcto, `parsear_webhook` procesa mensajes.
- `test_production_token_invalidado_rechaza` — con valor incorrecto en header, `parsear` retorna `[]`.
- `test_production_sin_header_rechaza` — sin header configurado, `parsear` retorna `[]`.
- `test_header_personalizable_via_env` — `WHAPI_WEBHOOK_HEADER` permite cambiar el nombre del header.

Comportamiento implementado

Escenario	Antes (P0 latente)	Ahora
WHATSAPP_PROVIDER=whapi + ENVIRONMENT=production + WHAPI_WEBHOOK_TOKEN vacío	Webhook /webhook acepta cualquier payload sin filtro. Atacante inyecta mensajes WhatsApp falsos.	RuntimeError al instanciar ProveedorWhapi -> obtener_proveedor() falla -> deploy aborta.
WHATSAPP_PROVIDER=whapi + production + token configurado + header válido	Acepta cualquier payload	Acepta solo si X-Webhook-Token coincide (hmac.compare_digest, timing-safe).
WHATSAPP_PROVIDER=whapi + production + token configurado + header inválido o ausente	Acepta cualquier payload	Rechaza con [] silenciosamente. Log warning.
WHATSAPP_PROVIDER=meta/twilio en producción (caso actual)	ProveedorWhapi ni se importa	Sin cambios — el check no afecta. Cero impacto en deploy actual.
Dev/test sin token	Aceptaba sin warning	Permisivo con warning explícito (solo dev/test).
Path runtime: provider creado en dev y luego ENVIRONMENT cambia a production	No protege	Defensa en profundidad: _verificar_firma rechaza igual.

Estado git

- **main local** en 49978a9, igual a origin/main. **Intacto.**
- **HEAD** en pr/whapi-webhook-token-obligatorio con 57584d4.
- **Sin push a main. Sin merge. Sin deploy.**

Lo que NO toque (según reglas)

- **agent/main.py** — sin cambios. El check vive en `__init__` del provider, igual que en T0.3.
- **WHAPI_TOKEN** — sin tocar (sigue usándose en transcribir y diagnóstico admin).
- **WHATSAPP_PROVIDER** — sigue siendo meta en Render.
- **Variables de Render** — ningún cambio.
- **Endpoints / parser** — sin cambios salvo el check al inicio de `parsear_webhook`.
- **Render / Vercel / secretos reales** — sin cambios. Tests usan dummies como 'shared_token_xyz', 'test_token_dummy'.
- **Merge a main** — no ejecutado.
- **Deploy** — no ejecutado.

Proximo paso recomendado (no implemento sin OK)

- **Revisar el PR en GitHub** desde el link de la portada.

- **Mergear cuando quieras:** con `WHATSAPP_PROVIDER=meta` el deploy de Render no se ve afectado (ProveedorWhapi ni se instancia).
- **Si en algun momento futuro** rotas a `WHATSAPP_PROVIDER=whapi`: setear `WHAPI_WEBHOOK_TOKEN` en Render con string aleatorio + configurar el header en panel Whapi via `PATCH /settings` con 'headers': `{'X-Webhook-Token': ''}`.
- **Housekeeping menor pendiente:** `WHAPI_API_URL` puede borrarse de Render (no se lee en codigo, ya documentado en `.env.example`).
- **Siguiente bloque grande:** verificacion operativa Stripe Dashboard -> T1.3 (gap funcional Stripe/backend de creditos).

Branch lista para merge. La decision queda en manos del owner.